AnkaCORE26_hafta4

1. Web Anatomisi HTTP Protokolü

HTTP durum kodları bize istemci ve sunucu arasına olan iletişimin sonucunu gösterir. Bir pentester için bu durum kodları çok önemlidir. Bu kodlar sayesinde uygulamanın iç mantığını anlayabilir.

200: İsteğin başarı ile işlendiğini ve içeriğe ulaşıldığını söyler. Yetkisiz birine 200 kodu dönüyorsa bu IDOR'a işaret olabilir.

302 Found: İstek başka bir URL üzerine yönlendirilir. Örnek olarak bir login sayfası olabilir. Bir pentester için erişmeye çalıştığımız dizinde 302 ile bir login sayfasına yönlendirilmemiz bir kimlik doğrulama kontrolü olduğunu gösterir. En basit tabiri ile bir web sayfasının geçici olarak yönlendirildiğini gösterir.

401: 401 durum kodu, hedef web sayfası için kimlik doğrulaması gerekli olduğunu veya kimlik doğrulaması gerektiğini söyler. Bir pentester için bu endpoint authentication istediğini gösterir. Hatalı login denemelerinde pentester 401 bekler. Farklı hata çıktıları alınırsa username enumeration aşamasına geçilebilir.

403: Burda 401 de benzer bir yan var. Bu sefer kimlik doğrulaması yapılmış ama yetkimizin olmadığı söyleniyor. Bir pentester için bu gayet iyi bir durum kodudur. Rol manipülasyonu, ID parametreleri değiştirme, Cookie manipülasyonu, HTTP metodunu değiştirme get metodunu post yapmak gibi, direkt olarak API endpoint çağırma gibi denmeler yapılabilir.

500: Bu durum kodu sunucu tarafında beklenmeyen hatayı belirtir. Bir pentester için gayet değerlidir. Beklenmeyen inputlar sonrasında 500 durum kodu alıyorsak, uygulama düzgün inputu güvenli bir şekilde işlemiyor olabilir.

2. Kimlik ve Yetki: "Sen Kimsin?"

Cookie (Çerezler): Cookieler tarayıcılarda saklanan verilerdir. Sunucu tarafından oluşturulup her istekte sunucuya gönderilir. Çoğunlukla içinde bir session ID bulundurur. Bir web sitesinde sayfayı yenilendiğimiz zaman bizim aynı kullanıcı olduğumuzu cookie ve birazdan anlatılacak session, token sayesinde anlar. Çünkü HTTP stateless yani durumsuz bir protokoldür, yani her istek bağımsızdır.

Session: Session, Türkçe adı ile oturum sunucu tarafında tutulur. Kullanıcı giriş yaptıktan sonra bir session kaydı oluşur. Kullanıcıya session ID verilir (Cookie içinde). Akış kısaca şu şekildedir: 1. Login olunur 2. Sunucu bir session ID üretir 3. Bu session ID cookie üzerine yazılır 4. Gelecekteki her istekte cookie otomatik gönderilir, böylelikle sunucu sizi session ID'den tanır.

Token: Tokenler genellikle stateless authentication için kullanılır.

Stateless Authentication: Kullanıcıya ait oturum bilgisini saklamadığı ve her istekte kimlik doğrulama bilgisinn (örneğin JWT gibi bir token) yeniden gönderildiği kimlik doğrulama yöntemidir.

Tokenlere kullanıcının kimliğini ve yetkilerini temsil eden bir dijital anahtar diyebiliriz.

En yaygın kullanılan token JWT'dir. Token çoğunlukla kullanıcı tarafında saklanmaz ve içinde kullanıcı bilgisi gömülüdür. Ayrıca imzalanmıştır yani değiştirilemez.

Authentication ve Authorization aralarındaki farklar nelerdir?

Siber güvenlikte en çok karıştırılan 2 kavramdan bahsedelim.

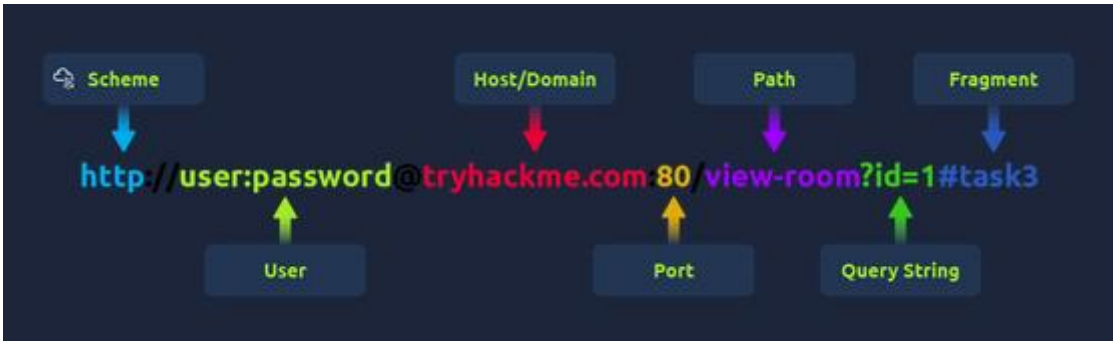
Öncelikle Authentication: Authenticaton bir kimlik doğrulama sürecini temsil eder. Giriş yapmaya çalıştığın sistem şunu der "sen gerçekten X kullanıcısı mısın?" Sistem bu soruya yanıt almak için de bizden belirli eylemler yapmanızı ister. Bunlar kullanıcı adı ve parola girmek, OTP kullanmak, Biyometrik doğrulama, MFA olabilir.

Authorization: Authorization yetkilendirmedir. Bir kullanıcı sistemde neler yapabilir neleri görebilir bunların belirlenmesine authorization deriz. Kullanıcı admin paneline girebilir mi? Dosyaları değiştirebilir mi? Bunların hepsinin belirlenmesidir. Bir hocam hep derdi, çok doğru ve bilinen bir cümle olduğunu düşünüyorum. "Kullanıcı yapacağı iş kadar yetki almalıdır".

3. Zafiyet Mimarisi: IDOR

IDOR (Insecure Direct Object Reference): kullanıcının erişim yetkisi kontrol edilmeden doğrudan bir nesneye erişebilmesi sonucu başkasına ait verilere ulaşabilmesi zafiyetidir. Örnek olarak user_id, order_id, dosya adı gibi nesneler. Az önce bahsettiğimiz **Authorization** sunucu tarafında kontrolü yapılmazsa IDOR ortaya çıkabilir. Sistem sadece kullanıcı kimliğini doğrulayıp ilgili kaynakla yetkisi olup olmadığını kontrol etmez.

Görev 1: İnternetin Röntgeni (TryHackMe)



Host nedir?

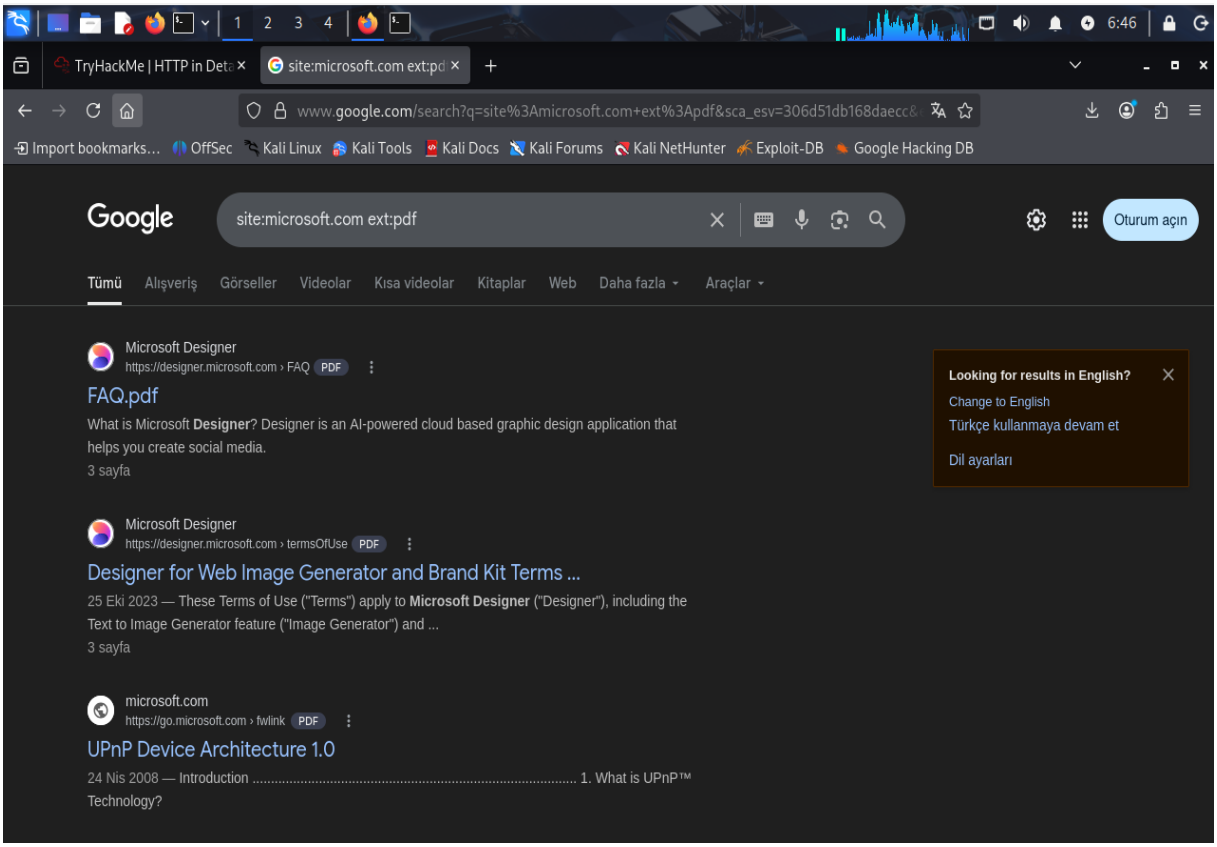
Host başlığı isteğin hangi domaine websitesine gönderildiğini belirtir. Sunucuya şunu der: "ben tryhackme.com adresine erişmek istiyorum".

```
GET / HTTP/1.1

Host: tryhackme.com
User-Agent: Mozilla/5.0 Firefox/87.0
Referer: https://tryhackme.com/
```

User-Agent Nedir?

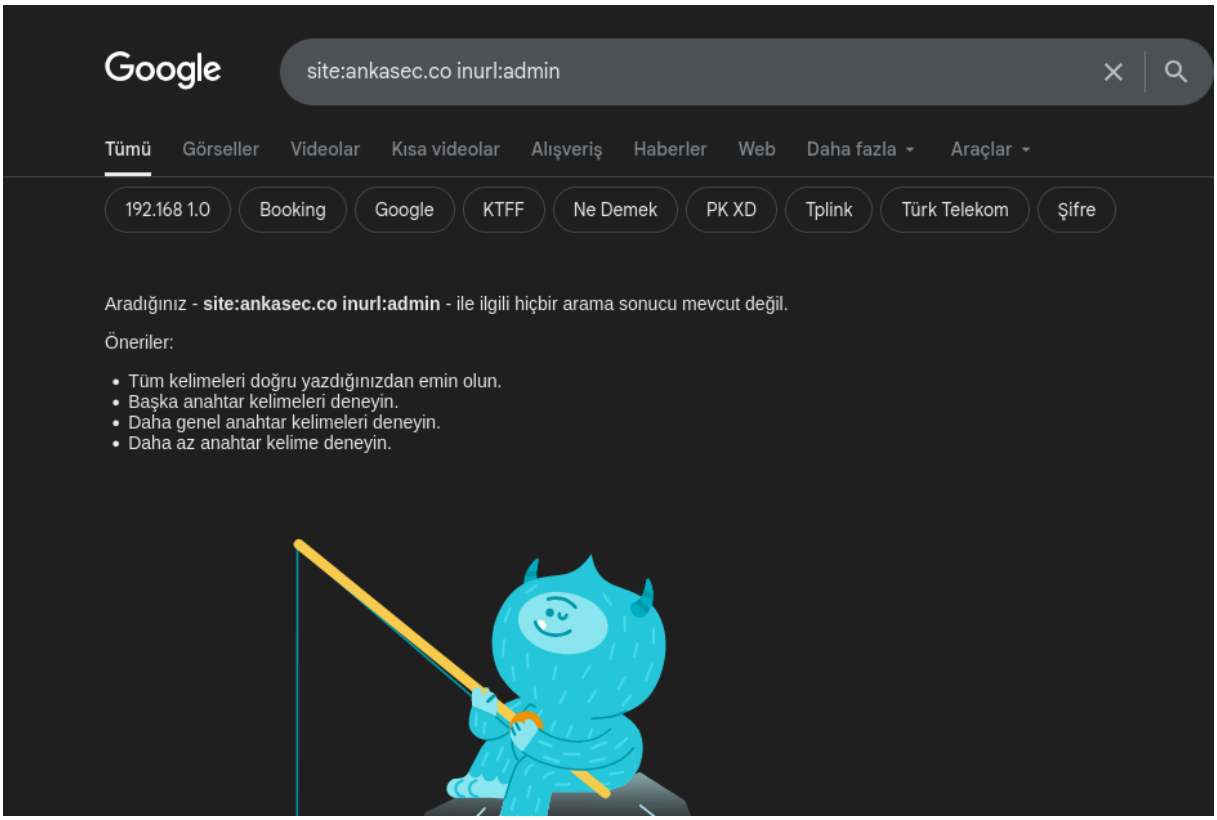
User-Agent başlığı isteği gönderen makine/istemci hakkında bilgi verir. Resimde görüldüğü gibi hangi tarayıcı kullanılıyor, hangi işletim sistemi, mobil mi bilgisayar mı gibi bilgiler gözükür. Bunun önemi şudur bazı siteler mobil ve masaüstünde farklılık gösterebilir. Botları engellemek için User-Agent kontrolü yapılabilir.

Görev 2: Google Dorking (Açık Kaynak İstihbaratı)



Site:Microsoft.com ext:pdf veya ext yerine filetype da yazılabilir.

Bu arama yöntemi hedef domain içinde dosya uzantısı pdf olan belgeleri aratır ve gösterir.



site:ankasec.co inurl:admin

Url içinde admin kelimesinin geçtiği sayfaları bulur ve listeler. Bu neden önemlidir?

Domain içerisindeki admin sayfasını bulmak için. Örnek olarak ankasec.co/admin veya admin/login gibi dizinleri arar. Bunları bulmak pentester için çok önemlidir, çünkü en basit yoldan credential spraying yapabilir.

Bu arama metodları sadece bunlarla kalmaz sql,zip,bak ve benzeri bir sürü dosya türlerini arayabiliriz. İlgilenenler için Google dork cheatsheet bıraktım, sadece pdf aramakla sınırlı olmadığını görebilirsiniz [Google dork cheatsheet · GitHub](#).

Cephe 1: Hayalet Avı (Recon Haritası)

Hedef ezviz.com

```
┌──(kali㉿kali)-[~]
└─$ subfinder -d ezviz.com -silent -o ilkenumeration.txt
bcard-admin.ezviz.com
job.ezviz.com
usmallglobalgateway.ezviz.com
bcard.ezviz.com
```

Subdomain Enumeration. Burada yazılan komut hedef domainin alt alan adlarını yani subdomainlerini toplar ve sonuçları istenilen yere yazdırır.

-d Hedef

-silent trafik olmaması için

-o output nereye ne şekilde kaydedeceksin sorusu

```
┌──(kali㉿kali)-[~]
└─$ cat ilkenumeration.txt | httpx -status-code -title -ip -tech-detect

    projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://mfs.ezviz.com [403] [18.66.102.113] [Amazon CloudFront,Amazon S3,Am
azon Web Services]
https://eumallglobalgateway.ezviz.com [404] [176.34.124.167] [HSTS]
https://usmallglobalgateway.ezviz.com [404] [52.71.189.6] [HSTS]
https://opensgp.ezviz.com [404] [404 Not Found] [161.117.188.154] [HSTS]
https://job.ezviz.com [200] [社会招聘] [163.171.128.188]
https://ieuopen.ezviz.com [200] [EZVIZ Cloud Developer Platform] [18.202.12
6.114] [Ant Design,HSTS,Next.js,Node.js,React,Webpack]
https://news.ezviz.com [302] [115.238.23.33] [PHP]
https://aliyunsgpovsmall.ezviz.com [302] [47.241.238.249]
https://www.ezviz.com [302] [47.241.238.249]
https://paycenter.ezviz.com [404] [404 Not Found] [47.241.238.249]
https://isrm.ezviz.com [301] [301 Moved Permanently] [163.171.128.188]
https://m.ezviz.com [302] [47.241.238.249]
https://pay.ezviz.com [403] [403 Forbidden] [60.190.232.40]
https://bcard-admin.ezviz.com [404] [124.160.120.34] [Nginx:1.20.2]
https://bcard-lite.ezviz.com [] [60.190.232.34] [Nginx:1.20.2]
https://icnopen.ezviz.com [302] [115.238.23.73] [Tengine]
https://pnr.ezviz.com [200] [EZVIZ Partner Portal] [47.236.62.166]
https://sapnr.ezviz.com [200] [EZVIZ Partner Portal] [1.178.33.170]
https://iusopen.ezviz.com [200] [EZVIZ Cloud Developer Platform] [34.232.24
2.171] [Ant Design,HSTS,Next.js,Node.js,React,Webpack]
https://b.ezviz.com [302] [302 Found] [60.190.232.40]
https://languageupdate.ezviz.com [403] [163.181.138.197] [Alibaba Cloud Obj
ect Storage Service,Tengine]
https://isgpopen.ezviz.com [200] [EZVIZ Cloud Developer Platform] [161.117.
188.154] [Ant Design,HSTS,Next.js,Node.js,React,Webpack]
https://pbservice.ezviz.com [301] [301 Moved Permanently] [115.238.23.33]
https://website1.ezviz.com [403] [403 Forbidden] [60.190.232.40]
https://isaopen.ezviz.com [200] [EZVIZ Cloud Developer Platform] [119.8.140
.234] [Ant Design,HSTS,Next.js,Node.js,React,Webpack]
https://iindiaopen.ezviz.com [200] [EZVIZ Cloud Developer Platform] [3.6.26
.229] [Ant Design,HSTS,Next.js,Node.js,React,Webpack]
https://service.ezviz.com [200] [萤石服务中心 - 萤石官网 - EZVIZ] [115.238.
23.33] [jQuery]
https://www.page.ezviz.com [200] [Follow EZVIZ on Social Media] [35.202.21.
90] [Google Analytics,HSTS]
https://support.ezviz.com [200] [EZVIZ Support - Creating Easy Smart Homes]
 [108.128.238.248] [FancyBox,Google Tag Manager,Tengine,jQuery:3.4.2]
```

Öncelikle httpx nedir ondan bahsedelim. Httpx devasa web varlıklarını hızlı bir şekilde analiz etmek için kullanılan bir araçtır. Bize adresin kullandığı teknoloji, durum kodu, http mi https mi, gerçekten canlı mı onları gösterir.

cat ilkenumeration.txt | httpx -status-code -title -ip -tech-detect komutunu açıklayalım.

| Yani pipe cat çıktısını httpx e aktarmasını sağlar.

-status-code bu bize http durumu kodunu gösterir 403,200 gibi.

-title taranan sayfaların başlıklarını listeler. Örneğin ekran görüntüsünde olan 萤石服务中心 - 萤石官网 – EZVIZ.

-ip düz mantık domainin çözümlendiği ip adresini gösterir.

-tech-detect web uygulamasında kullanılan teknolojileri tespit etmeye çalışır. Örneğin title örneğinde verdiğimiz örnekten ilerleyelim.

```
https://service.ezviz.com [200] [萤石服务中心 - 萤石官网 - EZVIZ] [115.238.
23.33] [jQuery]
https://www.page.ezviz.com [200] [Follow EZVIZ on Social Media] [35.202.21.
```

jQuery bir JS kütüphanesidir -tech-detect parametresi sayesinde bunu öğrenebildik.

Çoğu araçta olduğu gibi httpx de çok farklı kullanışlara sahiptir mesela.

cat ilkenumeration.txt | httpx -status-code | grep 200

Bu komutu yazdığımız zaman bize sadece 200 durumu koduna sahip olan yani sadece canlı olan adresleri sunacaktır.

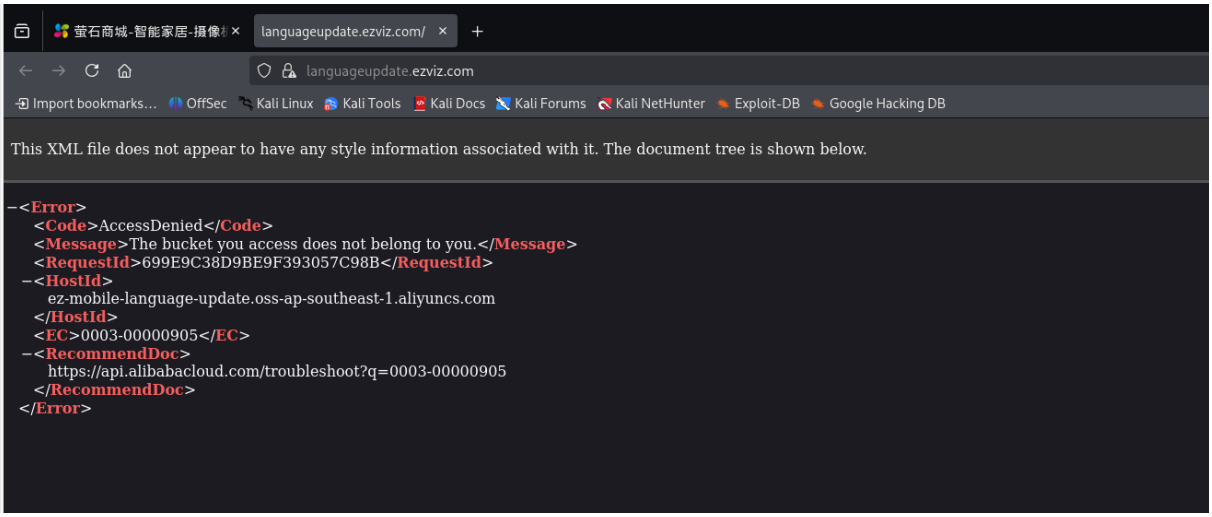
```
┌──(kali㉿kali)-[~]
└─$ cat ilkenumeration.txt | httpx -status-code | grep 200

    projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://ieuopen.ezviz.com [200]
https://support.ezviz.com [200]
https://job.ezviz.com [200]
https://iusopen.ezviz.com [200]
https://isgpopen.ezviz.com [200]
https://www.page.ezviz.com [200]
https://iindiaopen.ezviz.com [200]
https://isaopen.ezviz.com [200]
https://m-support.ezviz.com [200]
https://sapnr.ezviz.com [200]
https://service.ezviz.com [200]
https://pnr.ezviz.com [200]
https://pbm.ezviz.com [200]
```

Bulduğum en ilginç 3 subdomain.

https://pbm.ezviz.com/ Başlığının çince olması ilgimi çekti ve girdim. Girdikten sonra bir satış sitesi olduğunu farkettim. Bu çok önemli çünkü bunun gibi ticari işlem

yapabildiğiniz sitelerde, Price Tampering, IDOR, Priv Escalation gibi risk taşıyan alanları bulma ihtimali daha yüksektir.

https://languageupdate.ezviz.com/



Durum Kodu: 403

Kullanılan Teknolojiler: Alibaba Cloud Object Storage Service,Tengine

Bulut depolama kullanılıyor. Erişmek için yetkim olmadığı söyleniyor. Yekti politikaları unutulmuş bir dizin olabilir, dizinlere bruteforce yapıp diğer dizinlere keşif yapabiliriz.

https://ez-mobile-language-update.oss-ap-southeast-1.aliyuncs.com/ Bucket'ı üstüne gidebiliriz ama burada bulut depolama hakkında kuvvetli bilgilere sahip olmadığım için tek aklıma gelebilecek şey curl ile okuma testi yapmak olur.

https://bcard-lite.ezviz.com/

http durum kodu 500 (sunucu taraflı hata) ama API den 200 json yanıtı

Bu gerçekten ilginç geldi, belki normal bir durumdur bilemiyorum ama aynı anda hem 500 hatası hemde API'den 200 dönmesi. Sunucu ile API arasında tutarsızlık var. Gelen çince hata mesajı da "devam etmek için giriş yapmanız gerekiyor" diyor. Muhtemel olarak bcard yani "Bussines Card" gibi bir tür iş uygulaması. Sunucu Nginx/1.20.2 bu sürümde bilinen zafiyetler olabilir araştırılması lazım. Dizin taraması, header manipülasyonu, http metodu manipüsayonu denenebilir

bcard-lite.ezviz.com

Import bookmarks... OffSec Kali Linux Kali Tools Kali Do

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

```
code:      20020
message:   "需要登录后操作"
data:      null
```

JSON Raw Data Headers

Save Copy Pretty Print

{"code":20020,"message":"需要登录后操作","data":null}

JSON Raw Data Headers

Copy

Response Headers

Connection	keep-alive
Content-Type	application/json
Date	Wed, 25 Feb 2026 07:04:15 GMT
Server	nginx/1.20.2
Transfer-Encoding	chunked
Vary	Origin, Access-Control-Request-Method, Access-Control-Request-Headers

Request Headers

Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding	gzip, deflate, br, zstd
Accept-Language	en-US,en;q=0.5
Connection	keep-alive
Host	bcard-lite.ezviz.com
Priority	u=0, i
Sec-Fetch-Dest	document
Sec-Fetch-Mode	navigate
Sec-Fetch-Site	none
Sec-Fetch-User	?1
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

Cephe 2: Yetkiyi Delmek (PortSwigger Labs)

Lab: Insecure direct object references

APPRENTICE

LAB | Not solved

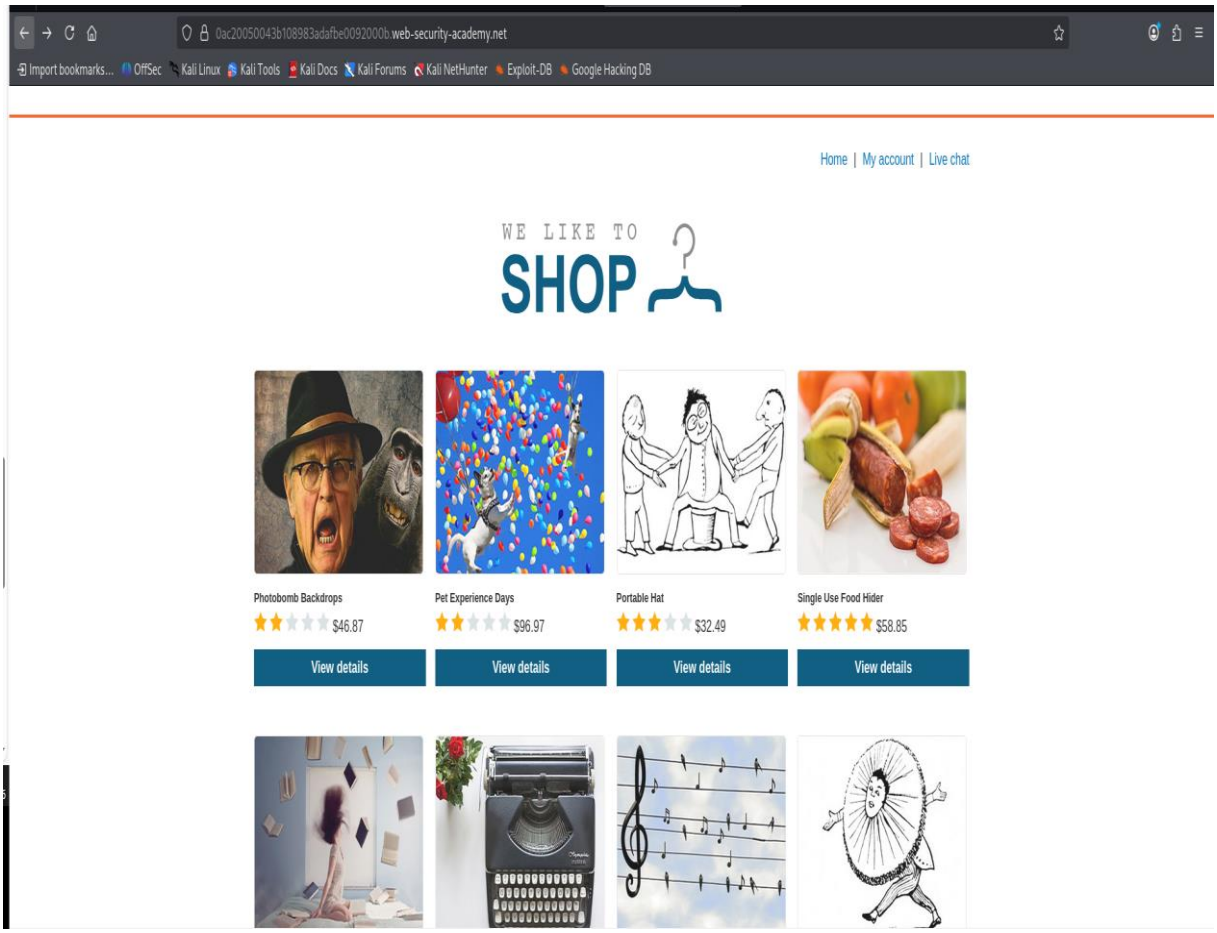
This lab stores user chat logs directly on the server's file system, and retrieves them using static URLs. Solve the lab by finding the password for the user `carlos`, and logging into their account.

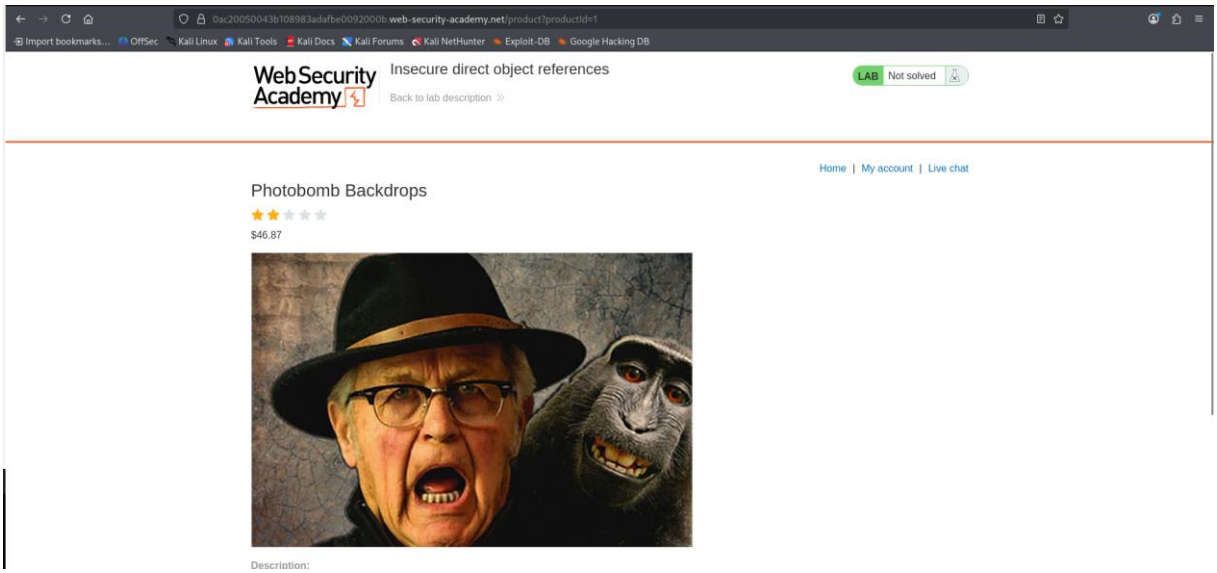
ACCESS THE LAB

Solution

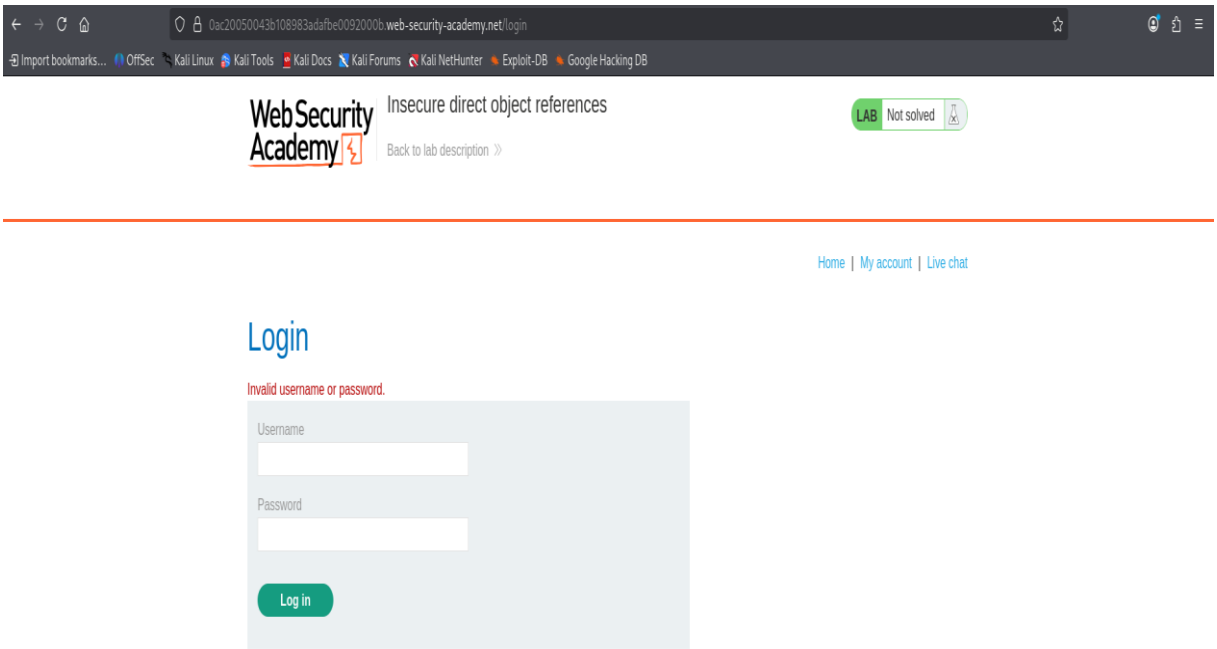
Community solutions

Çözeceğimiz makine burada. Şimdi IDOR senaryolarına bakacağız. Bize dediği şu bu makine kullanıcı chat loglarını direkt olarak sunucunun dosya sisteminde tutuyor ve onları statik adresler kullanarak alıyor.



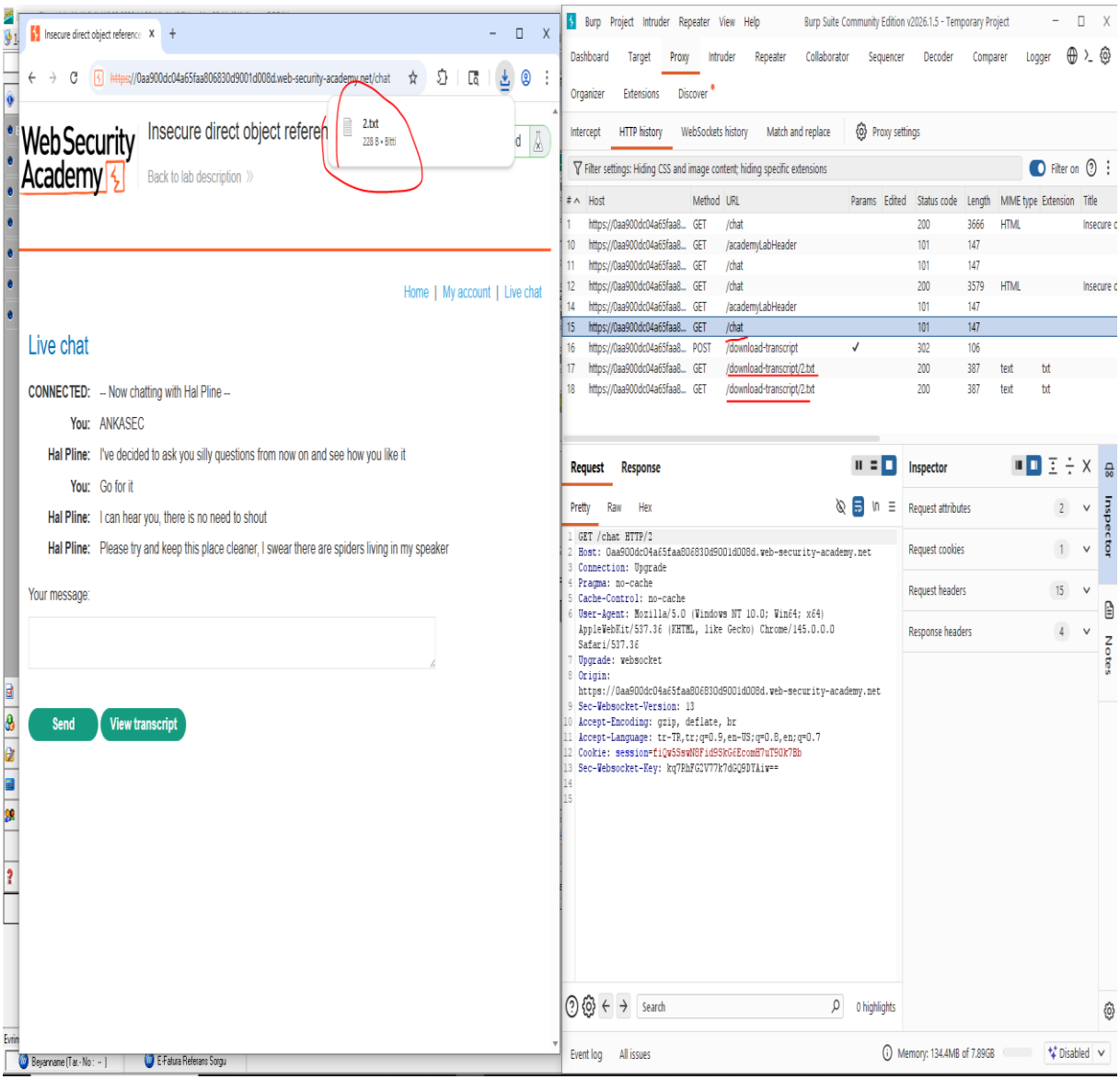


Site içerisindeki ürünlerin numaralarını değiştirdim ama gizli bir şey yoktu. Sadece önüme diğer ürünler çıkıyordu.



Not: VM den Windows makineye geçtim burp VM'i dondurdu (internetten aldı gibi düşünceler olmaması için)

Login olmak için basit credleri denedim ama sonuç yoktu.



Sonra live chat sayfasına girdim ve bir botla konuşmaya başladım. View transcript dediğimde 2.txt adlı bir dosya indirdi

İndirilen txt dosyasında CONNECTED: -- Now chatting with Hal Pline --
You: ANKASEC
Hal Pline: I've decided to ask you silly questions from now on and see how you like it
You: Go for it
Hal Pline: I can hear you, there is no need to shout

Burda bizim botla yaptıpımız konuşma duruyor. HTTP history'den GET metodu ile transcripti aldığımız bir istek var.

Send Cancel Burp AI Target: https://0aa900dc04a

Request

Pretty Raw Hex

```
GET /download-transcript/2.txt HTTP/2
Host: 0aa900dc04a65faa806830d9001d008d.web-security-academy.net
Cookie: session=fiQw5SswN8Fid9SkG6EcomH7uT90k7Bb
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://0aa900dc04a65faa806830d9001d008d.web-security-academy.net/ch
at
```

Search 0 highlights

İsteğin detaylarını burada görebiliyoruz.

Send Cancel Burp AI Target: https://0aa900dc04a

Request

Pretty Raw Hex

```
GET /download-transcript/0.txt HTTP/2
Host: 0aa900dc04a65faa806830d9001d008d.web-security-academy.net
Cookie: session=fiQw5SswN8Fid9SkG6EcomH7uT90k7Bb
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://0aa900dc04a65faa806830d9001d008d.web-security-academy.net/ch
at
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
HTTP/2 400 Bad Request
Content-Type: application/json; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 15

"No transcript"
```

Burp ile repeater kullanarak txt dosyasının numaralarını değiştirmeye karar verdim. Gördüğünüz gibi isteğin cevabı değişti ama bu sefer hiçbir içerik yok.

Request

Pretty Raw Hex

```
1  GET /download-transcript/1.txt HTTP/2
2  Host: 0aa900dc04a65faa806830d9001d008d.web-security-academy.net
3  Cookie: session=fiQw5SswN8Fid9SkG6EcomH7uT90k7Bb
4  Sec-Ch-Ua-Platform: "Windows"
5  Accept-Language: tr-TR,tr;q=0.9
6  Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
7  Sec-Ch-Ua-Mobile: ?0
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
   Safari/537.36
9  Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer:
   https://0aa900dc04a65faa806830d9001d008d.web-security-academy.net/ch
   at
```

Search 0 highlights

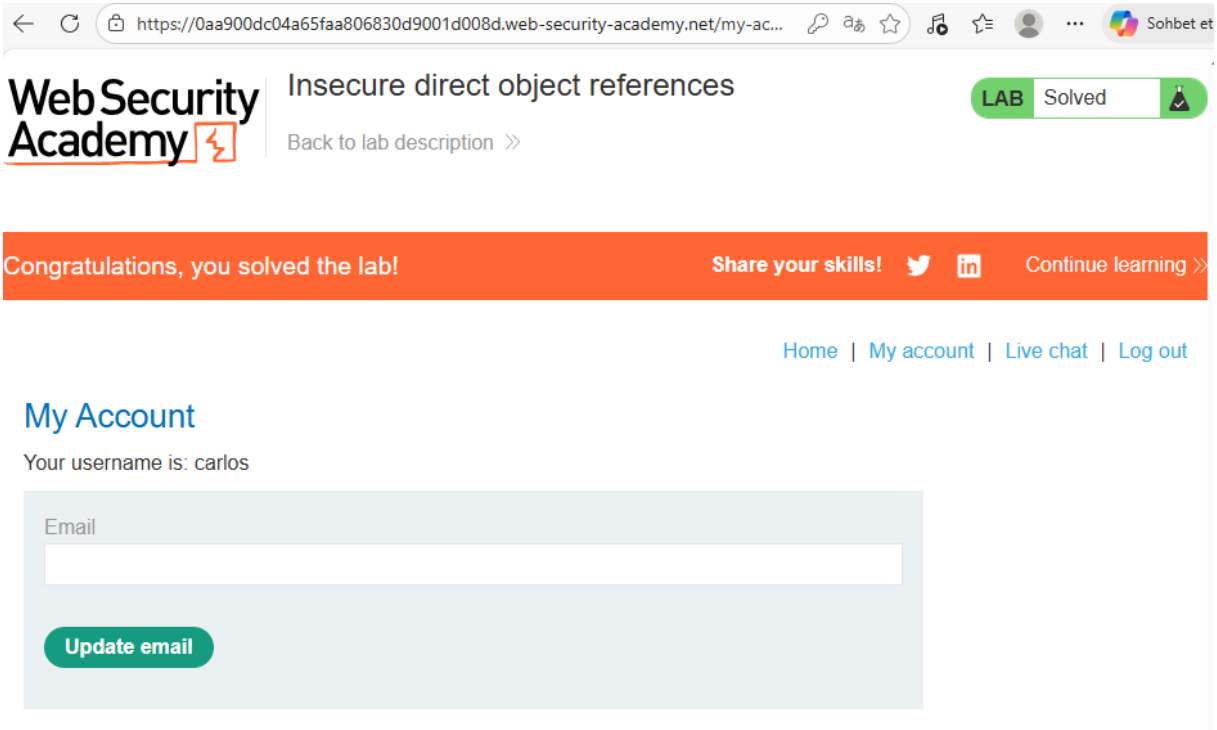
Response

Pretty Raw Hex Render

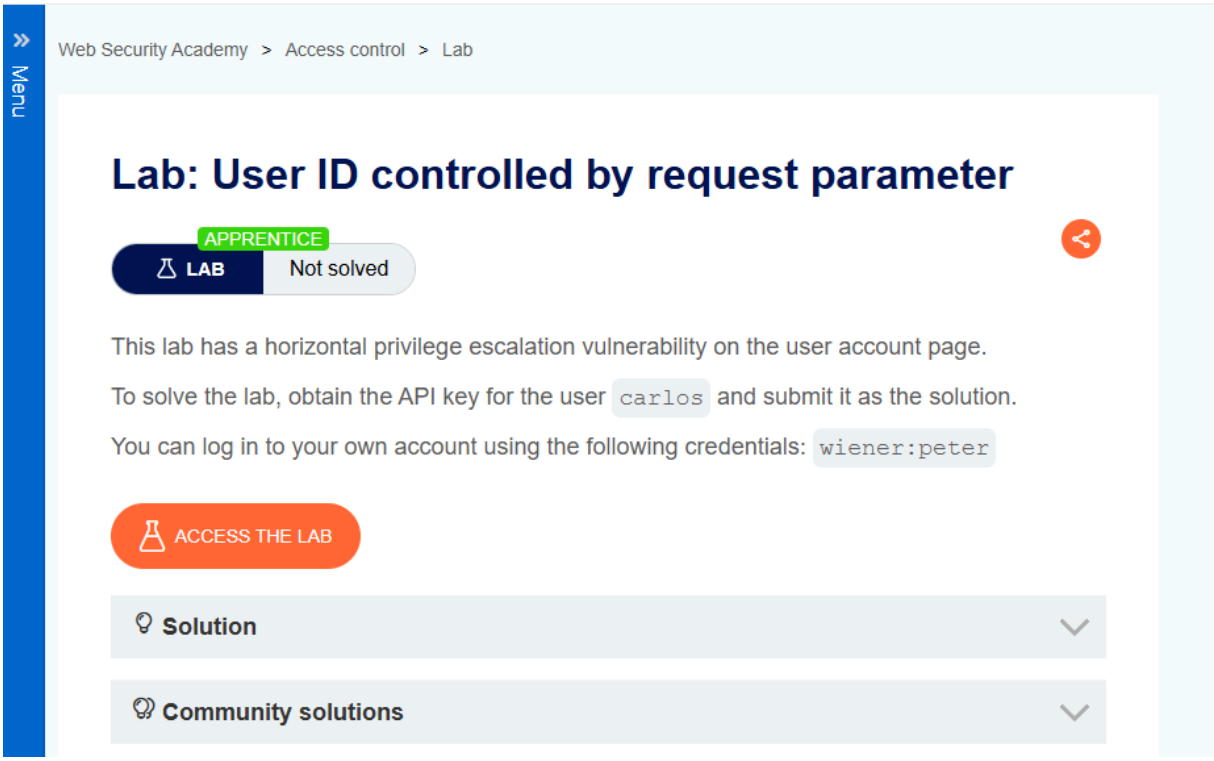
```
1  HTTP/2 200 OK
2  Content-Type: text/plain; charset=utf-8
3  Content-Disposition: attachment; filename="1.txt"
4  X-Frame-Options: SAMEORIGIN
5  Content-Length: 520
6
7  CONNECTED: -- Now chatting with Hal Pline --
8  You: Hi Hal, I think I've forgotten my password and need
   confirmation that I've got the right one
9  Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me
   your password and I'll confirm whether it's correct or not.
10 You: Wow you're so nice, thanks. I've heard from other people that
   you can be a right ****
11 Hal Pline: Takes one to know one
12 You: Ok so my password is 5vh0zpgwok4xfjiz9oel. Is that right?
13 Hal Pline: Yes it is!
14 You: Ok thanks, bye!
```

Search 0 highlights

1 dediğim zaman isteğin cevabında garip bir çıktı alıyoruz, konuşma esnasına kullanıcı bota parolasını vermiş.

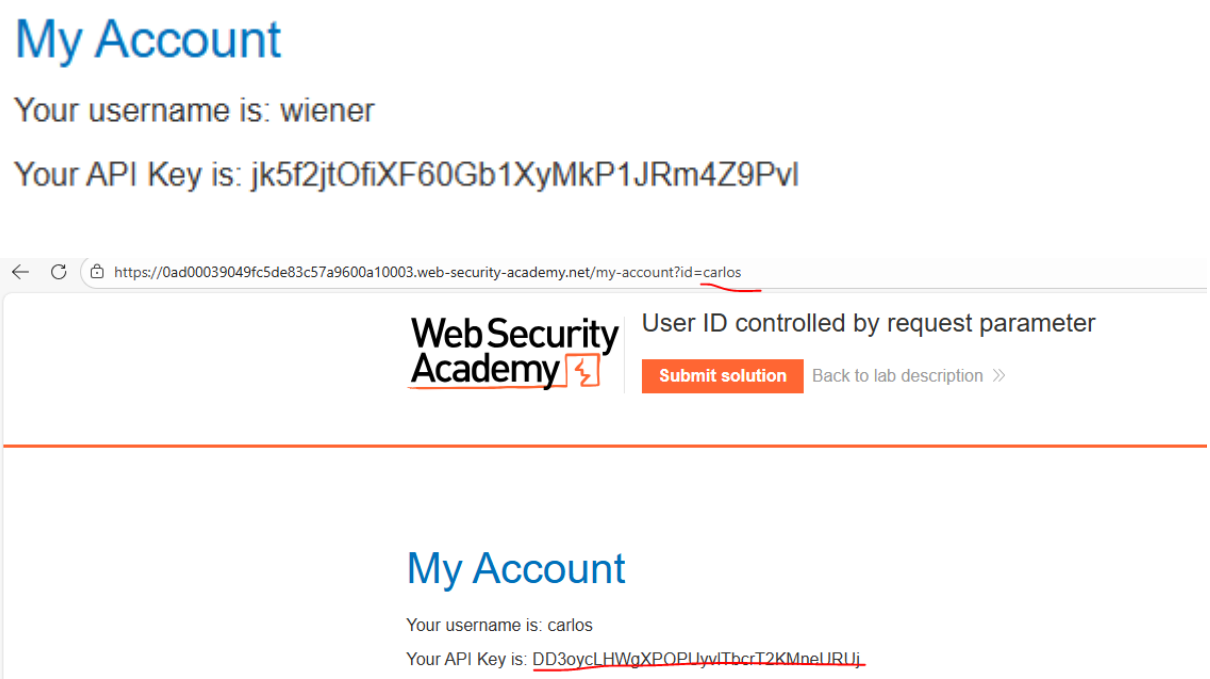


Carlos kullanıcı adı ile aldığımız şifreyi yazarak Carlos'un hesabına girip bu makineyi çözmüş bulunmaktayız.



Sıradaki makinemizde bizden istenilen Carlos kullanıcısının API anahtarını almak. Giriş yapacağımız hesap verilmiş wiener-peter.

Burada horizontal privilege escalation zafiyeti olduğu söyleniyor. Bu zafiyette normal bir kullanıcının başka bir aynı yetkiye sahip kullanıcıların verilerine erişilebiliyor.



Urldeki ID'yi kendi adımız yerine Carlos yaptığımız zaman çok basit bir şekilde API anahtarına ulaşabiliyoruz. Bunu burp aracılığı ile repeater üzerinden de yapabilirdik.

IDOR'un Gerçek Hayat Etkisi (Impact):

Senaryo: hastane.com/tahlil?id=500 bizim tahlil sonucumuz. Girişini 501 yani id=501 yaptığımızda başka kişinin sonucunu görebiliyoruz. Bu bir IDOR ve Broken Access Control zafiyetleridir. KVKK ve GDPR açısından etkileri şu şekildedir. Açıklamadan önce KVKK açısından bütün merak edilenler 6698 sayılı kanunda yazmaktadır bizim bu senaryoda bakacaklarımız madde 4,6,12,18 Mevzuat Bilgi Sistemi

KVKK açısından olası etkiler: İdari para cezası, Veri ihlali bildirim zorunluluğu, denetime uğrama, tazminat davaları.

GDPR açısından yine bütünlülük ve gizlilik ihlali, idari para cezası olası etkilerdir.

Marka İtibarına Etkileri: Bu verilerde test sonuçları ve kişisel veriler olduğu için. Böyle bir ifşalanma şirketin güvenini ve medyadaki imajını etkileyecektir. Bu da maddi değer kaybı anlamına gelir (eğer özel ise).

İşin Backend tarafında yapılmasını gerekenler şunlar:

Kullanıcı girişi authentication'a dikkat edilmeli. Sonra adım adım bunlar yapılmalıdır:

Kullanıcı girişini yaptı. Kullanıcının erişmeye çalıştığı yere izni var mı? Eğer izni yoksa yani o kaynağın sahibi değilse erişimi reddedilmelidir.